

Common Criteria (ISO/IEC 15408)

«Миллиметровка» международной оценки безопасности IT-продуктов. Это «общий язык» оценки безопасности во всём мире и ключ к пониманию российского ГОСТ Р ИСО/МЭК 15408 и логики сертификации ФСТЭК.

ТЕМА 3

Маркетинг против доказательств

Производитель **A**

«У нас военная криптография, всё очень безопасно»

Это **маркетинг**. Слово «очень безопасно» не поддаётся проверке.

Производитель **B**

> «У нас сертификат EAL4+»

Это **проверяемый технический язык**. Common Criteria — каркас, который превращает безопасность из «поверьте мне» в «я могу это доказать».



Что такое **Common Criteria?**

Common Criteria (CC) — международный стандарт **оценки свойств безопасности** IT-продуктов, официально ISO/IEC 15408.
Он нужен, чтобы результаты независимых оценок можно было сравнивать между собой.

1983

США выпускают TCSEC («Оранжевая книга») — военный стандарт

1991

Европа отвечает ITSEC

1996

Первая версия CC, объединившая опыт

1999

CC становится международным стандартом ISO/IEC 15408

2008

Россия принимает ГОСТ Р ИСО/МЭК 15408 (действующая редакция)

Ключевая мысль: CC — это не стандарт безопасности, а стандарт **оценки** безопасности.
Он не говорит «продукт обязан делать вот это». Он говорит: «как доказать, что продукт делает то, что заявил».

Три части — каркас, который надо запомнить

Часть	Название	Содержание
1	Введение и общая модель	Обзор и общая модель оценки
2	Функциональные требования безопасности	Каталог функций — «что продукт умеет»
3	Требования доверия к безопасности	Каталог гарантий — «как доказано, что он это умеет»

Часть **2 — «меню функций»**

Продукт говорит:
«у меня есть управление доступом» — это Часть 2.

Часть **3 — «меню доверия»**

То, что эта функция «протестирована, проанализирована, верифицирована» — это Часть 3.

Два типа требований

Функциональные требования

Активная защита: аутентификация, управление доступом, аудит, шифрование.

Требования доверия (гарантии)

Пассивное доверие: процесс разработки, глубина тестирования, анализ уязвимостей, управление конфигурацией.

Формула безопасности

Безопасность продукта = **сила функций × глубина гарантий**

Почему оба важны

Функции могут быть мощными, но без гарантий вы не знаете, реально ли они работают.



Что такое **EAL?**

Evaluation Assurance Level (Оценочный уровень доверия, ОУД) — заранее определённый набор требований доверия, от EAL1 до EAL7. Чем выше уровень — тем строже оценка, тем больше доказательств, тем дороже.

Уровень	Название	Смысл	Типичное применение
EAL1	Функционально протестирован	Функциональное тестирование	Продукты низкого риска
EAL2	Структурно протестирован	Структурное тестирование	Простые сетевые устройства
EAL3	Методически протестирован	Методическое тестирование	Устройства контроля доступа
EAL4	Методически спроектирован	Методическое проектирование	Банковские карты, паспорта
EAL5	Полуформально спроектирован	Полуформальное проектирование	ОС смарт-карт, HSM
EAL6	Полуформально верифицирован	Полуформальная верификация	Защищённые чипы
EAL7	Формально верифицирован	Формальная верификация	Военные/секретные системы

Что важно знать об **EAL**

1

EAL измеряет строгость оценки, а не силу функций

Продукт с EAL4 может иметь только базовое управление доступом, но его разработка, тесты и анализ уязвимостей проверены строго. Продукт с EAL2 может иметь кучу наворотов, но вы не знаете, надёжны ли они.

2

EAL4 — «золотая середина**»** коммерции

EAL4 называют «максимально достижимым коммерческим уровнем доверия». Выше — резкий рост стоимости, это оправдано только для смарт-карт и военных систем. Знак «+» означает добавление компонентов гарантии: EAL4+ обычно включает анализ уязвимостей AVA_VAN.5.

3

Российская система соответствия

ГОСТ Р ИСО/МЭК 15408 напрямую заимствует эту рамку. В сертификации ФСТЭК «уровень доверия» соответствует ей.

Ключевые понятия: PP и ST

Protection Profile (PP) — Профиль защиты

Набор требований безопасности для **класса продуктов**, независимый от конкретной реализации.

Пример: «профиль защиты межсетевого экрана», «профиль защиты ОС смарт-карт».

Зачем: заказчик говорит «мне нужен продукт, соответствующий такому-то PP». Производитель говорит «мой продукт соответствует». Все говорят на одном языке.

Security Target (ST) — Задание по безопасности

Заявление о требованиях безопасности для **конкретного продукта** — что он реализует и какого уровня доверия достигает.

Связь: PP — требования «для класса», ST — заявление «для конкретного продукта». Сертификация проводится именно по ST.

Российская практика: ФСТЭК для каждого типа СЗИ (например, СОВ, антивирус) разрабатывает профиль защиты, и при сертификации проверяет, соответствует ли продукт этому профилю.

Российский контекст: **CC** и ФСТЭК

1 Российский стандарт **=** русская версия международного

ГОСТ Р ИСО/МЭК 15408 технически идентичен ISO/IEC 15408.

2 Системы сертификации разделены

Сертификат, выданный западной лабораторией CC, в России автоматически не признаётся, и наоборот.

3 ФСТЭК перенимает методологию **CC**

С 2012 года ФСТЭК разрабатывает профили защиты для типов СЗИ на основе CC и требует от производителей сертифицироваться по заданию по безопасности (ЗБ).

Важно! Если вы делаете продукт безопасности в России, вы одновременно живёте в двух логиках: международный язык CC и отечественные требования ФСТЭК. Цели одни, но материалы, формы и процедуры оценки разные. Понимать CC — значит понимать, куда движется ФСТЭК.





Итог

> Common Criteria превращает оценку безопасности из «субъективной веры» в «объективное доказательство».

EAL

Шкала доверия — от EAL1 до EAL7. Измеряет строгость оценки, а не силу функций.

PP

Договор для класса продуктов — независимый от реализации набор требований безопасности.

ST

Заявление конкретного продукта — что он реализует и какого уровня доверия достигает.

Понимание Common Criteria — это понимание «общего языка» международной и российской оценки безопасности IT-продуктов, а также логики сертификации ФСТЭК.